

Reconnaissance Toolkit

A Practical Cheatsheet for Penetration Testers

This cheatsheet covers the reconnaissance (information-gathering) tools most commonly used by professional penetration testers during the OSINT and enumeration phases of an engagement — before any exploitation occurs. It is organized by category: passive OSINT, DNS/subdomain enumeration, network/port scanning, web reconnaissance, and email/breach data lookup.

Scope & Ethics: Only use these tools against systems you own or are explicitly authorized to test (signed scope of work / rules of engagement). Unauthorized scanning or enumeration of third-party systems is illegal in most jurisdictions.

Contents

1. Passive OSINT & Footprinting
2. DNS & Subdomain Enumeration
3. Network & Port Scanning
4. Web Application Reconnaissance
5. Email, Breach Data & Metadata
6. Recon Workflow Summary

1. Passive OSINT & Footprinting

Passive recon gathers information without directly interacting with target systems, reducing detection risk.

theHarvester

Aggregates emails, subdomains, hosts, employee names, and open ports from public sources (search engines, PGP servers, Shodan, etc.).

Install: apt install theharvester | pip install theHarvester

```
theHarvester -d target.com -b all
theHarvester -d target.com -b google,bing,linkedin -l 200
theHarvester -d target.com -b shodan -f output.html
```

Recon-ng

Modular web reconnaissance framework with a Metasploit-like console; automates OSINT collection via API-driven modules (Whois, Shodan, GitHub, breach data, etc.).

Install: apt install recon-ng | pip install recon-ng

```
recon-ng
[recon-ng][default] > marketplace install all
[recon-ng][default] > workspaces create target
[recon-ng][target] > modules load recon/domains-hosts/hackertarget
[recon-ng][target] > options set SOURCE target.com
[recon-ng][target] > run
```

Maltego

Graph-based OSINT and link-analysis tool. Visualizes relationships between domains, people, companies, IPs, and social media accounts using 'transforms'.

Install: GUI app — download from [maltego.com](https://www.maltego.com) (Community Edition is free)

```
1. New Graph -> drag a Domain entity onto canvas
2. Right-click entity -> Run Transform -> 'To DNS Name'
3. Chain transforms: Domain -> Subdomains -> IPs -> Netblocks
```

Tip: Best used to visually map an organization's external footprint for client reports.

Shodan / Shodan CLI

Search engine for internet-connected devices; reveals exposed services, banners, SCADA/IoT devices, and default-credential targets indexed by IP or organization.

Install: pip install shodan then shodan init <API KEY>

```
shodan search org:"Target Corp"
shodan host 8.8.8.8
shodan domain target.com
shodan search "apache" country:US port:8080
```

Google Dorking / GHDB

Uses advanced search operators to surface exposed files, login portals, and misconfigurations indexed by Google.

Install: No install — browser based (Google Hacking Database on [exploit-db.com](https://github.com/g0tmilk/gdhs))

```
site:target.com filetype:pdf
site:target.com inurl:admin
site:target.com intitle:"index of" "backup"
site:pastebin.com "target.com" password
```

2. DNS & Subdomain Enumeration

whois

Queries domain registration records — registrar, name servers, creation/expiry dates, and (if not redacted) registrant contact info.

Install: apt install whois

```
whois target.com
whois 8.8.8.8
```

dig / nslookup

Core DNS query utilities for resolving records manually and testing for zone transfer misconfigurations.

Install: Preinstalled on most Linux distros (dnsutils package)

```
dig target.com ANY
dig target.com MX +short
dig axfr target.com @ns1.target.com # zone transfer test
nslookup -type=TXT target.com
```

Amass

OWASP project for in-depth attack-surface mapping: combines passive sources, brute-forcing, and DNS resolution to enumerate subdomains and related infrastructure.

Install: apt install amass | snap install amass

```
amass enum -d target.com
amass enum -passive -d target.com -o subs.txt
amass intel -org "Target Corp"
```

Sublist3r

Fast subdomain enumeration using search engines, VirusTotal, and DNSdumpster as sources.

Install: pip install sublist3r | git clone + pip install -r requirements.txt

```
python3 sublist3r.py -d target.com
python3 sublist3r.py -d target.com -o subs.txt -t 20
```

dnsrecon / dnsenum

DNS enumeration scripts for record dumps, zone transfers, and subdomain brute-forcing using wordlists.

Install: apt install dnsrecon dnsenum

```
dnsrecon -d target.com -t std,brt
dnsenum --enum target.com -f subdomains.txt
```

assetfinder / subfinder

Lightweight Go-based tools for quickly discovering subdomains from passive sources; commonly chained with httpx for live-host filtering.

Install: go install github.com/tomnomnom/assetfinder@latest | go install github.com/projectdiscovery/subfinder/v2/cmd/subfinder@latest

```
subfinder -d target.com -silent
assetfinder --subs-only target.com | httpx -silent
```

3. Network & Port Scanning

This is 'active' recon — it directly touches target infrastructure and should only be run within an authorized scope.

Nmap

The industry-standard network mapper for host discovery, port scanning, service/version detection, and OS fingerprinting via the Nmap Scripting Engine (NSE).

Install: apt install nmap

```
nmap -sn 10.0.0.0/24 # host discovery (ping sweep)
nmap -ss -p- -T4 target.com # full TCP SYN port scan
nmap -sV -sC -p 22,80,443 target.com # version + default scripts
nmap -O target.com # OS fingerprinting
nmap --script vuln target.com # vulnerability scan scripts
```

Masscan

Extremely fast asynchronous port scanner capable of scanning the entire IPv4 space in minutes; typically used to find open ports quickly before feeding into Nmap for detail.

Install: apt install masscan

```
masscan -p1-65535 10.0.0.0/24 --rate=10000
masscan -p80,443 target_range.txt -oL results.txt
```

Tip: Pair with nmap -iL results.txt -sV for detailed follow-up on discovered ports.

Netcat (nc)

Swiss-army-knife networking utility for banner grabbing, manual port checks, and simple listeners during recon and later exploitation stages.

Install: apt install netcat-traditional

```
nc -nv target.com 80 # banner grab
nc -zv target.com 20-100 # simple port scan
```

Zenmap

Official GUI front-end for Nmap; useful for visual topology maps and saving/comparing scan results across engagements.

Install: apt install zenmap

```
Launch GUI -> enter target -> choose profile (e.g. 'Intense scan')
```

4. Web Application Reconnaissance

WhatWeb

Fingerprints web technologies — CMS, JavaScript frameworks, web servers, analytics IDs, and version numbers.

Install: apt install whatweb

```
whatweb target.com
whatweb -v -a 3 target.com
```

Wappalyzer

Browser extension / CLI that identifies the technology stack of a website (CMS, frameworks, hosting, analytics).

Install: Browser extension, or: npm install -g wappalyzer

```
wappalyzer https://target.com
```

httpx

Fast HTTP probing tool used to check which discovered subdomains/hosts are live, and capture status codes, titles, and tech stack.

Install: go install github.com/projectdiscovery/httpx/cmd/httpx@latest

```
cat subs.txt | httpx -title -status-code -tech-detect
httpx -l subs.txt -o live_hosts.txt
```

Gobuster / ffuf

Directory, file, and subdomain brute-forcers used to discover hidden paths, backup files, and admin panels via wordlists.

Install: apt install gobuster | go install github.com/ffuf/ffuf@latest

```
gobuster dir -u https://target.com -w /usr/share/wordlists/dirb/common.txt
gobuster dns -d target.com -w subdomains.txt
ffuf -w wordlist.txt -u https://target.com/FUZZ
```

Wayback Machine / waybackurls

Pulls historical URLs and archived snapshots of a site from web.archive.org — often reveals old endpoints, parameters, or leaked files no longer linked publicly.

Install: go install github.com/tomnomnom/waybackurls@latest

```
waybackurls target.com | sort -u > archived_urls.txt
```

BuiltWith

Web-based technology profiler showing hosting provider, CMS, analytics, widgets, and third-party integrations for a domain.

Install: No install — builtwith.com (web service, API available)

```
Browse to builtwith.com/target.com
```

5. Email, Breach Data & Metadata

Hunter.io

Discovers and verifies corporate email address patterns for a target domain, useful for phishing-simulation and social-engineering scoping.

Install: Web/API service — hunter.io (free tier + API key)

```
curl "https://api.hunter.io/v2/domain-search?domain=target.com&api_key=KEY"
```

Have I Been Pwned (HIBP)

Checks whether email addresses or domains appear in known public data breaches — useful for assessing credential-reuse risk.

Install: Web/API service — haveibeenpwned.com (API key required for domain search)

```
curl -H "hibp-api-key: KEY" https://haveibeenpwned.com/api/v3/breachedaccount/user@target.com
```

exiftool

Extracts EXIF/metadata from documents and images harvested during recon — can reveal usernames, software versions, GPS data, and internal file paths.

Install: `apt install libimage-exiftool-perl`

```
exiftool document.pdf
exiftool -a -u -g1 image.jpg
```

Metagoofil / FOCA

Harvests public documents (pdf, doc, xls, ppt) from a target domain and extracts metadata (usernames, software, internal paths) to build a footprint of the organization.

Install: `git clone metagoofil` (GitHub) | FOCA is a Windows GUI tool

```
python3 metagoofil.py -d target.com -t pdf,doc,xls -l 50 -o results -f results.html
```

LinkedIn / Social Media OSINT (manual)

Employee names, job titles, and org structure gathered manually or via tools like CrossLinked to support phishing pretexts and username-format guessing.

Install: CrossLinked: `git clone + pip install -r requirements.txt`

```
python3 crosslinked.py -f '{first}.{last}@target.com' target-company-name
```

6. Recon Workflow Summary

A typical order of operations professionals follow, moving from fully passive to lightly active techniques:

Step	Goal	Example Tools
1	Domain & org footprint	whois, Google dorking, BuiltWith
2	Subdomain enumeration	Amass, Sublist3r, subfinder, dnsrecon
3	Live host discovery	httpx, Nmap host discovery (-sn)
4	Port & service scanning	Masscan (fast sweep) -> Nmap (detail)
5	Web tech fingerprinting	WhatWeb, Wappalyzer, httpx -tech-detect
6	Content/dir discovery	Gobuster, ffuf, waybackurls
7	People & email OSINT	theHarvester, Hunter.io, LinkedIn, CrossLinked
8	Breach / credential exposure	Have I Been Pwned, dehashed-style sources
9	Consolidate & visualize	Maltego, Recon-ng, spreadsheet/report

Reminder: Always operate within a documented scope of work and rules of engagement. Rate-limit active scans against production systems, log all activity for your report, and disclose findings responsibly through agreed channels.